

Abuse web browsers for fun & profits

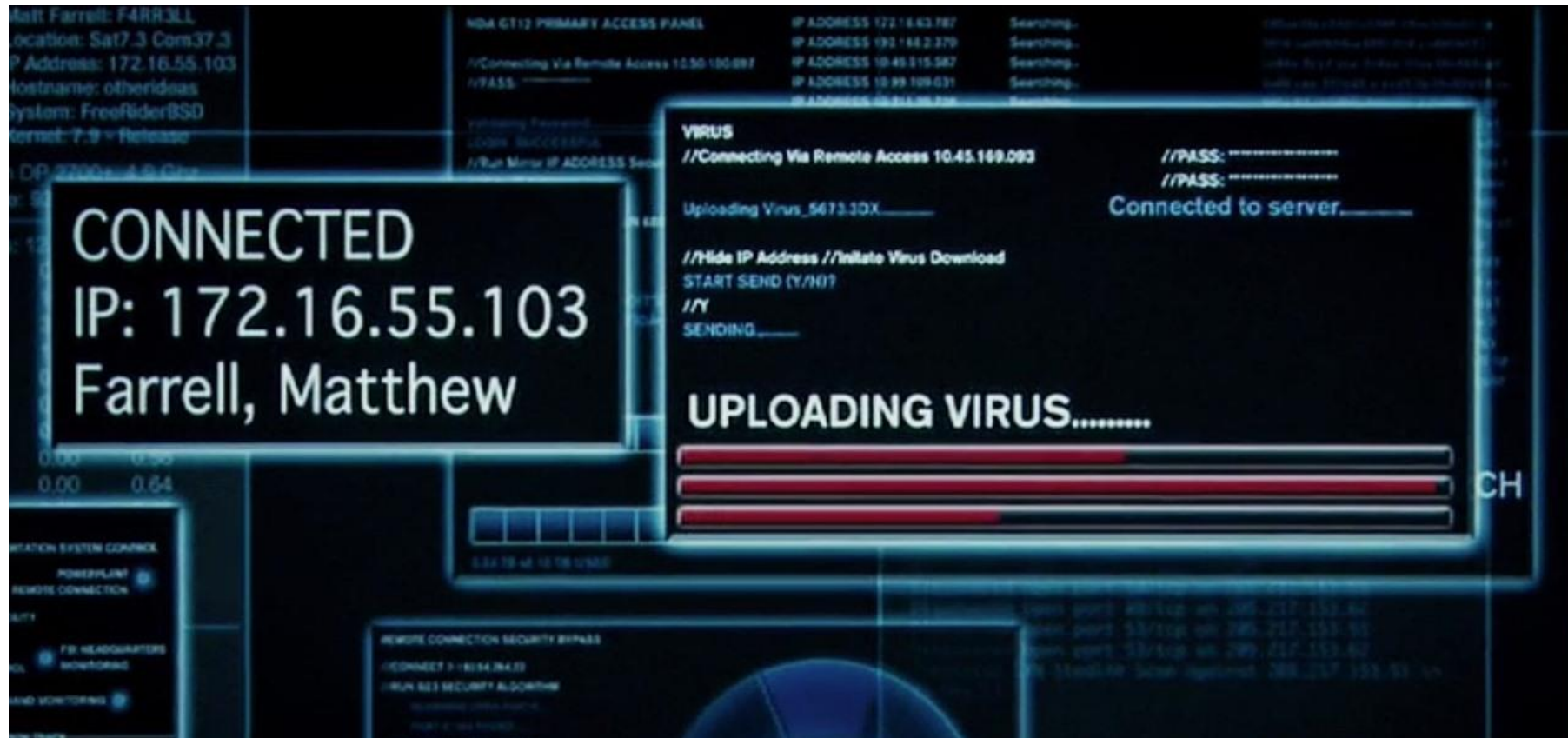


Dominique Righetto, Excellium
@righettod



Warning

- This talk will not contain stuff like this

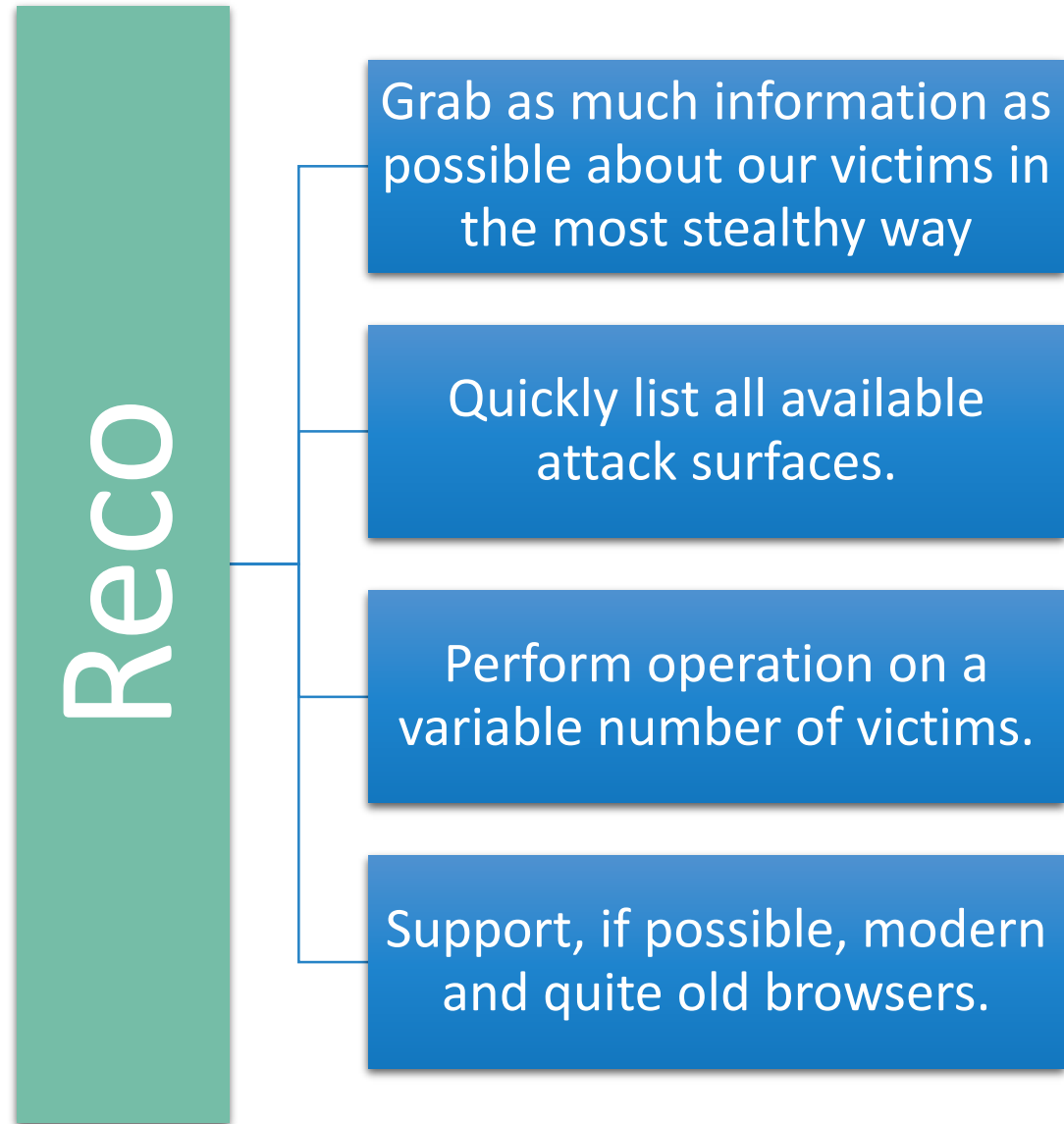


Why abusing browsers?

- Today modern web browsers on Mobile or Desktop :
 - Contains plenty of features through native components or plugins.
 - Are used as preferred client to access new applications.
 - Most of the new applications are web based (thanks Mister Cloud 😊).
- Security at infrastructure/network is now quite mature.
- Targeting client side and users are more “fruitful” because you can’t standardize people behavior or mindset.

Our problem

- As **penetration tester**, the most important step on a attack is dedicated to **reconnaissance and analysis** of the target entity.
- Based on the offline analysis of the grabbed data, we can further create attack scenarii and customize related content.



Our friend



HTML5

*Cross Origin Resource Sharing.
WebSocket.*



JavaScript

*New native features + JQuery (branch 1.x).
Some other JavaScript libraries for specific job
like hashing or cookie management.*



PIWIK

*Building block for report rendering and keep
gathered data in-house.*



PHP / Symfony / Composer

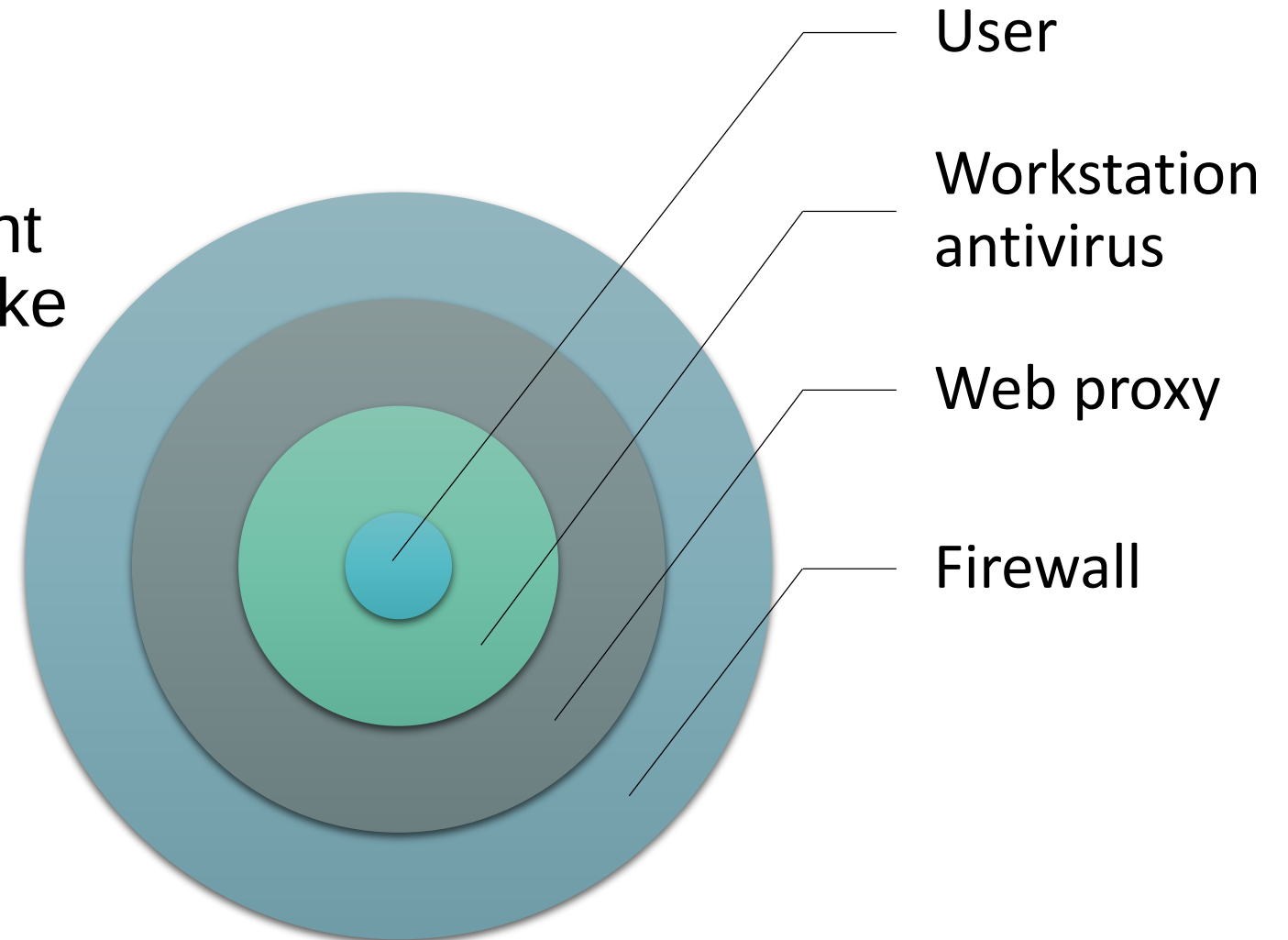
*Handle server side operations.
Our team is composed by PHP integrist so we
can't fight 😊*

Note about CORS and Web Socket

- **Same Origin Policy** (SOP for friends) is a pillar of the security on the web because it restricts the capacity of an hidden caller (for example Ajax) to contact arbitrary domain in a easy way (most bypass was using JSONP type call or loading through tags like IMG/SCRIPT/STYLE/IFRAME...).
- But thanks to HTML5...
 - Web Socket is currently not restricted by the SOP.
 - CORS configuration is HTTP headers based so, an attacker can easily configure CORS on his domain to accept any call.

Our enemies

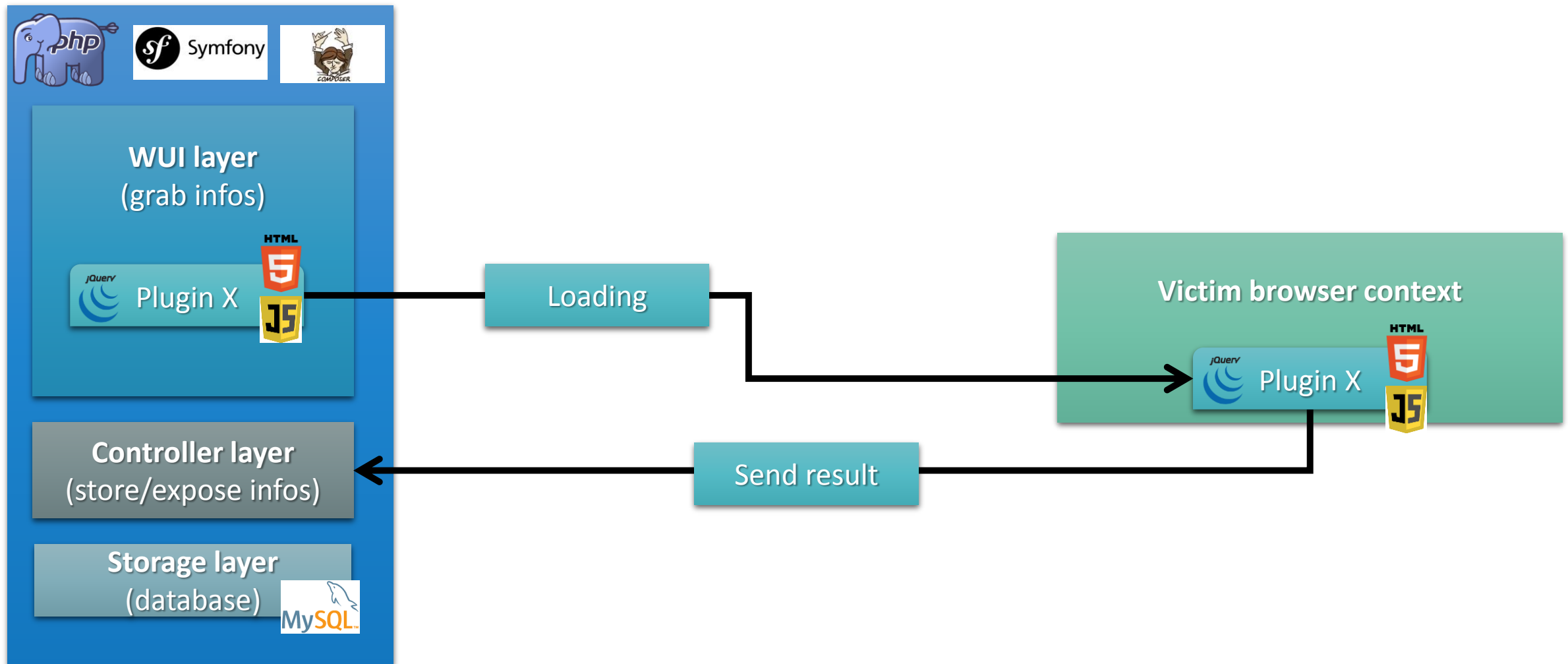
- As we will use only legal web client side technologies and we want to be stealth, we must take care about:



Global approach

- Implements a simple web application, plugins based, in which each plugin:
 - Will be executed on client side.
 - Will be in charge of grabbing a specific information.
- Information will be grouped by entity targeted and a visitor (victim) will have a unique ID in order to track it.
- URL will be provided to victims using the following vectors:
 - Phishing (in our campaign, each time, more than 30% of the targeted users click 😊).
 - Via compromising of a "water hole" site.

Global approach



Interesting information

- As the final objective is to determine one or several attack surfaces and according to browser capacities, the following information are interesting for us:
 - Browser name/version + all plugins info + OS name/version:
 - Will be used to find a plugin or a browser vulnerable (ex: IE < 11 because Microsoft do not update them anymore since February 2016).
 - Will be used also to determine the type of user because, for example, often Sys Admin user:
 - Have special plugins like one for VMWARE.
 - Have local admin or privileged rights ☺

Interesting information

- Web Socket support level by Browser and Web Proxy:
 - Will be used to know if we can use Web Socket to create a 2 way communication channel because Web Socket is not limited by the Same Origin Policy.
- Site categories on which the user is allowed to browse:
 - Will be used to know if we can use site like Twitter/GitHub/Pastebin/GoogleDrive/Dropbox...for data infiltration/exfiltration.

Interesting information

- File type allowed to be downloaded by the victim from the web:
 - Will be used to know, using which file type, we can use as infection vector to deliver the attack.
- Specific services running on the victim workstation like Tomcat, MySQL, Oracle, SonarQube, WAS...
 - Will be used to know if the victim is a developer because often developer:
 - Have local admin or privileged rights 😊
 - Workstation can contains interesting credentials or information.
 - Have a set of exception rules about Antivirus real-time scanning.

Interesting information

- Identify the name and version of the Web Proxy:
 - Will be used to find vulnerability and bypass for data infiltration or exfiltration.
- CPU and GPU information of the victim workstation:
 - Will be used to create a malware that only executes if it detect this type of CPU/GPU and then escape malware sandboxes.

Interesting information

- Type of Internet connection:
 - Will be used to determine the download / upload capacities of the victim infrastructure and then provides which exfiltration capacity that can be used for data infiltration or exfiltration.
 - Will also be used to determine if the victim work from home/public WIFI....Useful to find additional attack surfaces...

Plugin n°1 - Approach

- Browser name/version + all plugins info + OS name/version:
 1. On modern browsers, use the native object « *navigator.plugins* » to retrieve plugins list.
 2. Enhance detection using the library « *PluginDetect* » in order to support old browsers:
 - <http://www.pinlady.net/PluginDetect/>
 3. Retrieve user agent and OS information using the library « *UAParser* »:
 - <https://github.com/faisalman/ua-parser-js>

Plugin n°1 - Data sample

```
1 {
2   "Browser" : {
3     "Name" : "Firefox",
4     "Version" : "46.0"
5   },
6   "Operating System" : {
7     "Name" : "Windows",
8     "Version" : "8.1"
9   },
10  "User Agent" : "Mozilla/5.0 (Windows NT 6.3; WOW64; rv:46.0) Gecko/20100101 Firefox/46.0"
11 }
```

```
1 [
2   {
3     "description" : "Adobe PDF Plug-In For Firefox and Netscape 15.10.20056",
4     "filename" : "nppdf32.dll",
5     "name" : "Adobe Acrobat",
6     "version" : "15.10.20056.36345"
7   },
8   {
9     "description" : "Citrix Receiver Plugin (Win32)",
10    "filename" : "npicaN.dll",
11    "name" : "Citrix Receiver",
12    "version" : "14.2.100.14"
13  },
14  {
15    "description" : "Citrix URL-Redirection Helper Plugin ",
16    "filename" : "npURLInterceptorPlugin.dll",
17    "name" : "Citrix URL-Redirection Helper Plugin ",
18    "version" : "14.2.100.14"
19  },
20  {
21    "description" : "Version 5.41.3.0",
22    "filename" : "npgoogletalk.dll",
23    "name" : "Google Talk Plugin",
24    "version" : "5.41.3.0"
25  },
26  {
27    "description" : "Version 5.41.3.0",
28    "filename" : "npoid.dll",
29    "name" : "Google Talk Plugin Video Renderer",
30    "version" : "5.41.3.0"
31  },
32  {
33    "description" : "Google Update",
34    "filename" : "npGoogleUpdate3.dll",
35    "name" : "Google Update",
36    "version" : "1.3.29.5"
37  },
38  {
39    "description" : "Google Update",
40    "filename" : "npGoogleUpdate3.dll",
41    "name" : "Google Update",
42    "version" : "1.3.29.5"
43  },
44  {
45    "description" : "NPRuntime Script Plug-in Library for Java(TM) Deploy",
46    "filename" : "npdeployJava1.dll",
47    "name" : "Java Deployment Toolkit 8.0.770.3",
48    "version" : "11.77.2.3"
49  },
50  {
51    "description" : "Next Generation Java Plug-in 11.77.2 for Mozilla browsers",
52    "filename" : "npj2.dll",
53    "name" : "Java(TM) Platform SE 8 U77",
54    "version" : "11.77.2.3"
55  }
56 ]
```

Plugin n°2 - Approach

- Web Socket support level by Browser and Web Proxy:
 1. Detect if browser support Web Socket using the native object *"window.WebSocket"*.
 2. If browser support WS then try to send a unique message to the open relay *"echo.websocket.org"*:
 - If we receive, in response, the message sent → Web Proxy support WS.
 - Otherwise → Web Proxy do not support WS.

Plugin n°2 - Data sample

```
1  {  
2    "Browser" : true,  
3    "Proxy"   : true  
4  }
```

Plugin n°3 - Approach

- Site categories on which the user is allowed to browse:
 - During the plugin implementation:
 1. A list of site, with their associated category, has been built by grabbing the information against several Web Proxy vendors (ex: Palo Alto / Bluecoat...)
 2. The list of site has been grouped by Web Proxy vendor and has been enhanced with custom local sites and categories (ex: l'essentiel, itnations, paperjam....).
 3. For each site, the smallest image available has been searched on it and was kept as reference test link.
 4. So, the list of sites is now a list of links grouped by categories and Web Proxy vendor.

Plugin n°3 - Approach

- Site categories on which the user is allowed to browse:
 - Plugin processing:
 - For each link, a HTML IMG tag is generated and added to DOM.
 - A random url parameter, in order to avoid caching by the browser, is added to all url links.
 - Each HTML IMG contains a handler on the following events:
 - "onload" : Set the flag indicating that the site is allowed because the image can be loaded.
 - "onerror" : Set the flag indicating that the site is NOT allowed because the image cannot be loaded.

Plugin n°3 - Data sample

```
1  [
2    {
3      "category" : "PEER-TO-PEER",
4      "isAllowed" : "Y",
5      "provider" : "PALO_ALTO",
6      "url" : "http://www.bitcomet.com/images/support_email.png"
7    },
8    {
9      "category" : "MILITARY",
10     "isAllowed" : "Y",
11     "provider" : "PALO_ALTO",
12     "url" : "http://www.goarmy.com/static/images/share_nav/linkedin.png"
13   },
14   {
15     "category" : "MILITARY",
16     "isAllowed" : "Y",
17     "provider" : "PALO_ALTO",
18     "url" : "http://www.defense.gov/portals/1/Images/army.jpg"
19   },
20   {
21     "category" : "QUESTIONABLE",
22     "isAllowed" : "Y",
23     "provider" : "PALO_ALTO",
24     "url" : "http://0.static.collegehumor.cvcdn.com/jument/images/placeholders/175x98.png"
25   },
26   {
27     "category" : "QUESTIONABLE",
28     "isAllowed" : "Y",
29     "provider" : "PALO_ALTO",
30     "url" : "http://pixel.quantserve.com/pixel/p-83WcMqNwwE46.gif"
31   },
32   {
33     "category" : "TRANSLATION",
34     "isAllowed" : "Y",
35     "provider" : "PALO_ALTO",
36     "url" : "http://www.wordreference.com/images/speaker-index2.png"
37   },
38   {
39     "category" : "GOVERNMENT",
40     "isAllowed" : "N",
41     "provider" : "PALO_ALTO",
42     "url" : "http://www.ca.gov/images/template2012/clear.gif"
43   },
44   {
45     "category" : "GOVERNMENT",
46     "isAllowed" : "Y",
47     "provider" : "PALO_ALTO",
48     "url" : "http://sfgov.org/images/311.png"
49   },
```

```
524   {
525     "category" : "BUSINESS_AND_ECONOMY",
526     "isAllowed" : "Y",
527     "provider" : "PALO_ALTO",
528     "url" : "http://www.geisheker.com/wp-content/uploads/2013/04/10steps-400px.jpg"
529   },
530   {
531     "category" : "HACKING",
532     "isAllowed" : "Y",
533     "provider" : "PALO_ALTO",
534     "url" : "http://packetstatic.com/img1398360120/ps_logo.png"
535   },
536   {
537     "category" : "EDUCATIONAL_INSTITUTIONS",
538     "isAllowed" : "Y",
539     "provider" : "PALO_ALTO",
540     "url" : "http://www.111c.lu/images/logo.png"
541   },
542   {
543     "category" : "WEB_HOSTING",
544     "isAllowed" : "Y",
545     "provider" : "XLM",
546     "url" : "http://www.ovhtelecom.fr/images/2015/ico-reseau-ovh.png"
547   },
548   {
549     "category" : "COMPUTER_AND_INTERNET_INFO",
550     "isAllowed" : "Y",
551     "provider" : "PALO_ALTO",
552     "url" : "http://www.redhat.com/profiles/rh/themes/redhatdotcom/img/logo-summit.png"
553   },
554   {
555     "category" : "RELIGION",
556     "isAllowed" : "Y",
557     "provider" : "PALO_ALTO",
558     "url" : "http://www.biblesociety.ca/sites/all/modules/contribute/languageicons/flags/fr.png"
559   },
560   {
561     "category" : "HACKING",
562     "isAllowed" : "Y",
563     "provider" : "XLM",
564     "url" : "http://www.exploit-db.com/wp-content/uploads/2015/04/edb-2015-theme-logo641.png"
565   },
566   {
567     "category" : "ALCOHOL_AND_TOBACCO",
568     "isAllowed" : "Y",
569     "provider" : "PALO_ALTO",
570     "url" : "http://www.thompsoncigar.com/assets/images/cms/global/arrow.jpg"
571   }
572 ]
```

Plugin n°4 - Approach

- File type allowed to be downloaded by the victim from the web:
 - During the plugin implementation:
 1. A list of specific files that can be used as infection vector has been built.
 2. Each file is linked to its digest using SHA-256 algorithm.
 - Example of tested files format:
 - Microsoft Office supporting auto start VBA macros and OLE packages.
 - Windows native and .Net binaries.
 - Java auto executable archive.
 - Adobe Portable Data Format.
 - Windows Script File.

Plugin n°4 - Approach

- File type allowed to be downloaded by the victim from the web:
 - Plugin processing:
 - For each file
 1. Send a Ajax GET request in order to retrieve the file content.
 2. Compare the computed hash of the retrieved file content against the hash associated to the file.
 3. If they match → File type allowed to be downloaded and not altered by Web Proxy.
 4. Otherwise → File type not allowed to be downloaded or altered by Web Proxy.

Plugin n°4 - Data sample

```
1  [
2    {
3      "file.doc" : "success : 200"
4    },
5    {
6      "file.docx" : "success : 200"
7    },
8    {
9      "file.exe" : "success : 200"
10   },
11   {
12     "file.jar" : "success : 200"
13   },
14   {
15     "file.pdf" : "success : 200"
16   },
17   {
18     "file.wsf" : "success : 200"
19   },
20   {
21     "file.xls" : "success : 200 but corrupt (not same SHA256)"
22   },
23   {
24     "file.xlsx" : "success : 200"
25   }
26 ]
```

Plugin n°5 - Approach

- Specific services running on the victim workstation like Tomcat, MySQL, Oracle, SonarQube, WAS...
- Based on research performed by Lavakumar Kuppan & Manish Saindane:
 - <http://www.andlabs.org/tools/jsrecon/jsrecon.html>

Plugin n°5 - Approach

- Specific services running on the victim workstation like Tomcat, MySQL, Oracle, SonarQube, WAS...
 1. Test open state of dedicated ports on victim loopback IP address using Web Socket.
 2. Analyze the time taken by the WS "*readyState*" attribute to move from initial state **0** to further state **1/2/3**.
 3. According to the delay taken, the open/closed/filtered state is deducted.

Constant	Value	Description
CONNECTING	0	The connection is not yet open.
OPEN	1	The connection is open and ready to communicate.
CLOSING	2	The connection is in the process of closing.
CLOSED	3	The connection is closed or couldn't be opened.

Plugin n°5 - Data sample

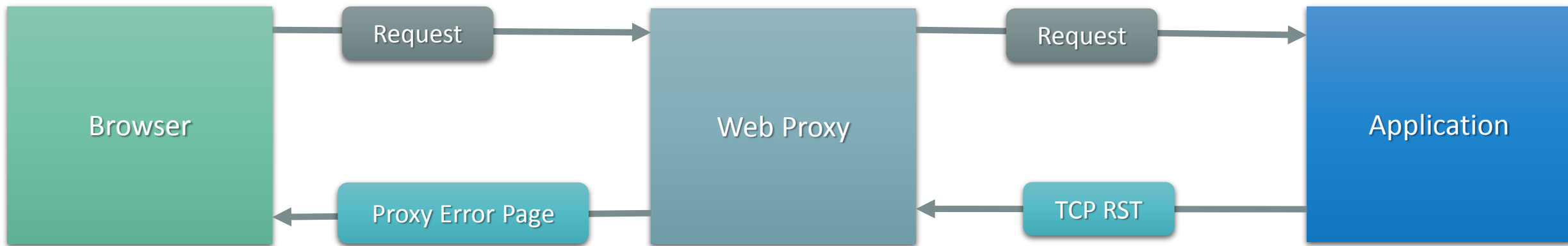
```
1  [  
2    {  
3      "name" : "tomcat_unsecure",  
4      "port" : 8080,  
5      "state" : "CLOSED"  
6    },  
7    {  
8      "name" : "tomcat_secure",  
9      "port" : 8443,  
10     "state" : "CLOSED"  
11   },  
12   {  
13     "name" : "was_unsecure",  
14     "port" : 9080,  
15     "state" : "CLOSED"  
16   },  
17   {  
18     "name" : "was_secure",  
19     "port" : 9043,  
20     "state" : "CLOSED"  
21   },  
22   {  
23     "name" : "mysql_unsecure",  
24     "port" : 3306,  
25     "state" : "OPEN"  
26   },  
27 ]
```

```
{  
  "name" : "oracle_unsecure",  
  "port" : 1521,  
  "state" : "CLOSED"  
},  
{  
  "name" : "sqlserver_unsecure",  
  "port" : 1433,  
  "state" : "CLOSED"  
},  
{  
  "name" : "webserver_unsecure",  
  "port" : 80,  
  "state" : "OPEN"  
},  
{  
  "name" : "webserver_secure",  
  "port" : 443,  
  "state" : "CLOSED"  
},  
{  
  "name" : "sonarqube_unsecure",  
  "port" : 9000,  
  "state" : "CLOSED"  
}  
]
```

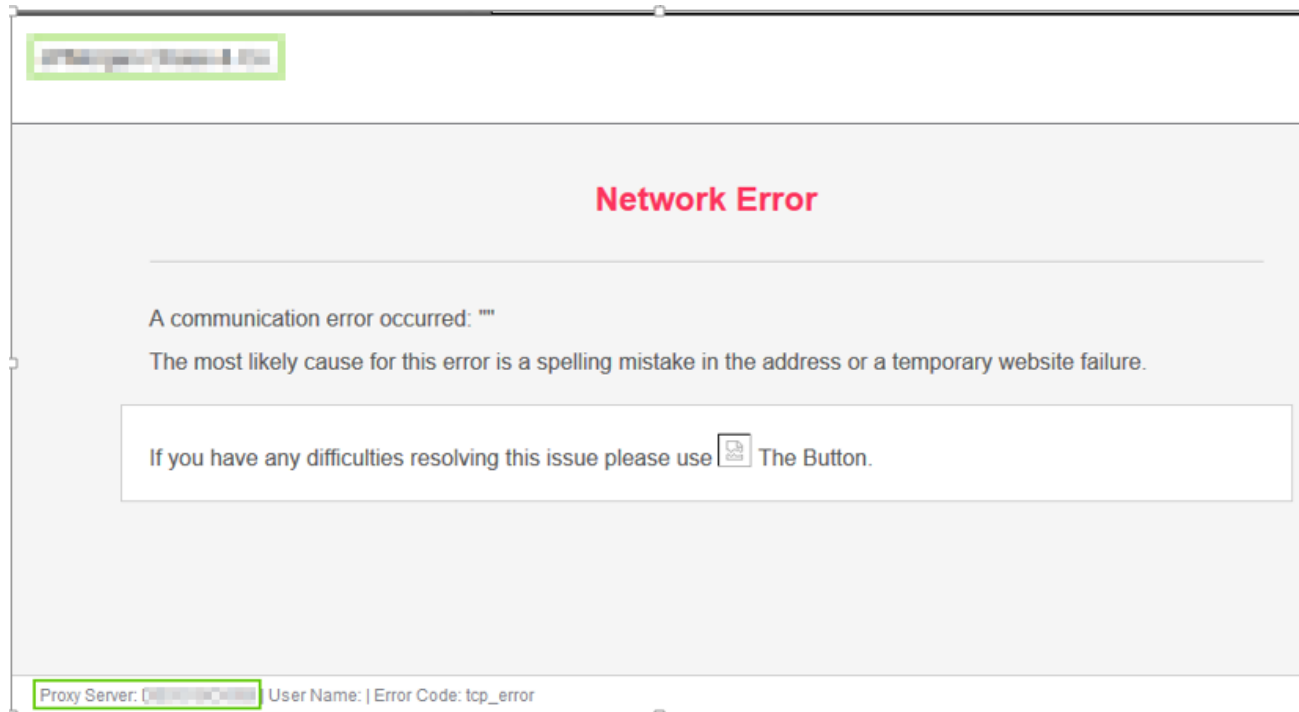
Plugin n°6 - Approach

- Identify the name and version of the Web Proxy:
 1. Analyze request HTTP header to detect presence of headers added by the Web Proxy like for example: X-Cache-Lookup, X-Cache, Via...
 2. Capture the **Web Proxy error page** by returning a **TCP RESET** to a specific Ajax GET request.
 3. Use Cross Origin Resource Sharing to send error page captured to storage controller.

Plugin n°6 - Approach



Plugin n°6 - Data sample



```
1 {
2   "Added": [
3     {
4       "via": [
5         "1.1 [redacted] (squid/3.1.23)"
6       ]
7     },
8     {
9       "x-forwarded-for": [
10        "192.168.16.21, 176.[redacted]"
11      ]
12    }
13  ]
14 }
```

Plugin n°7 - Approach

- CPU and GPU information of the victim workstation :
 1. Retrieve CPU information using the library "*UAParser*" and the native object "*navigator.platform*".
 2. Retrieve number of CPU Core using the native object "*navigator.hardwareConcurrency*".
 3. Retrieve GPU information using HTML5 Canvas and the extension "*WEBGL_debug_renderer_info*" if this one is available otherwise get information from Canvas object instance directly.

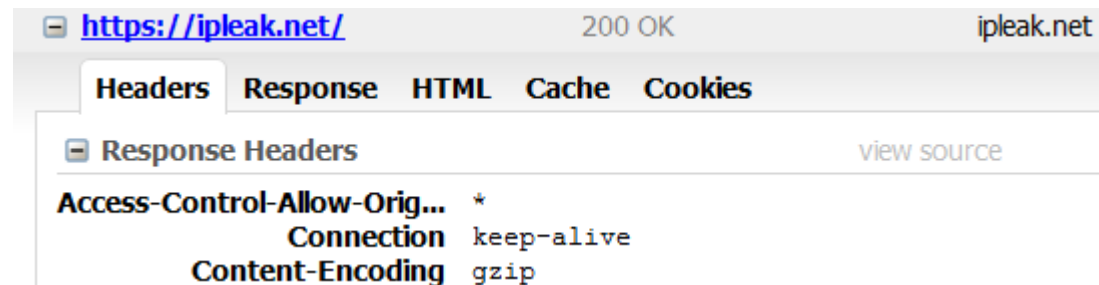
Plugin n°7 - Data sample

```
1 {
2   "CPU" : "Win32, architecture : amd64, ",
3   "GPU" : {
4     "Display" : "1600 x 900 - 24bits/pixel",
5     "Extensions" : [
6       "ANGLE_instanced_arrays",
7       "EXT_blend_minmax",
8       "EXT_color_buffer_half_float",
9       "EXT_frag_depth",
10      "EXT_shader_texture_lod",
11      "EXT_texture_filter_anisotropic",
12      "OES_element_index_uint",
13      "OES_standard_derivatives",
14      "OES_texture_float",
15      "OES_texture_float_linear",
16      "OES_texture_half_float",
17      "OES_texture_half_float_linear",
18      "OES_vertex_array_object",
19      "WEBGL_color_buffer_float",
20      "WEBGL_compressed_texture_etc1",
21      "WEBGL_compressed_texture_s3tc",
22      "WEBGL_depth_texture",
23      "WEBGL_draw_buffers",
24      "WEBGL_lose_context",
25      "MOZ_WEBGL_lose_context",
26      "MOZ_WEBGL_compressed_texture_s3tc",
27      "MOZ_WEBGL_depth_texture"
28    ],
29    "Renderer" : "Mozilla",
30    "Shading language" : "WebGL GLSL ES 1.0",
31    "Vendor" : "Mozilla",
32    "Version" : "WebGL 1.0"
33  }
34 }
```

Plugin n°8 - Approach

- Type of Internet connection :

1. If the site <https://ipleak.net> can be browsed by the victim then perform an Ajax request on it → Site allow CORS request from anyone 😊

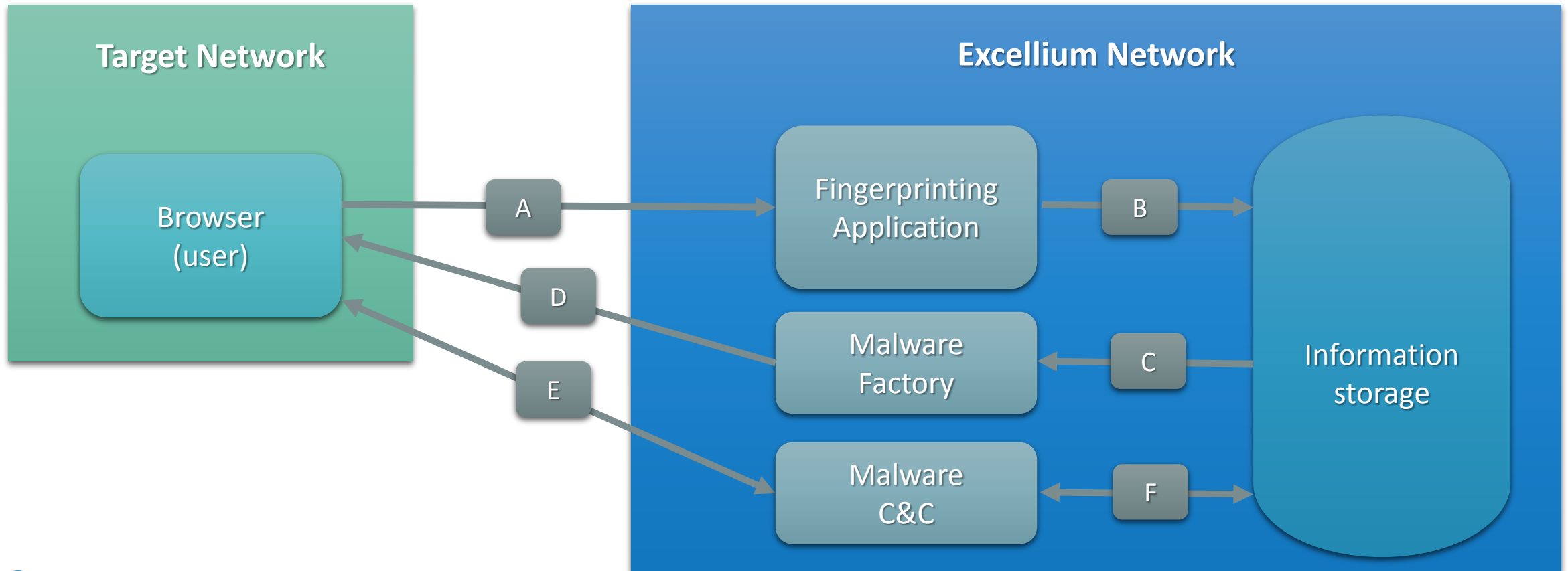


2. Parse page to extract information about Internet connection.

Plugin n°8 - Data sample

```
1  {
2      "ASN:" : "AS6661 Entreprise des Postes et Telecommunications",
3      "Accuracy Radius" : "13 KM",
4      "AirVPN Exit Node:" : "No",
5      "City:" : "Esch-sur-alzetteAccuracy: 23%",
6      "Country:" : "Luxembourg (LU)Accuracy: 99%",
7      "Data Age" : "Sat, 23 Apr 2016 07:51:04 +0000",
8      "Domain:" : "pt.lu",
9      "IP" : "83.99.3.179",
10     "ISP:" : "Entreprise des Postes et Telecommunications",
11     "Latitude & Longitude:" : "49.4958 , 5.9806",
12     "Net Speed:" : "Cable/DSL",
13     "Organization:" : "Entreprise des Postes et Telecommunications",
14     "Region:" : "Luxembourg (03)Accuracy: 83%",
15     "Reverse Lookup:" : "",
16     "TOR Exit Node:" : "No",
17     "Time Zone:" : "Europe/Luxembourg",
18     "Type:" : "Residential"
19 }
```

Global attack process resume



Which possible mitigation?

- To be honest, it's very difficult to block extraction of the information described into this presentation...
- However, some action can be put in place to limit the amount of disclosed data, it's a matter of attack surface available.

Which possible mitigation?

- The following actions try to reduce the attack surface available:
 - Limit, to the minimum possible according the business need, the number of plugins installed in browsers : in 2016 Flash is still really needed? Same question about Java runtime registration into browser?
 - Keep browsers, plugins and OS up to date:
 - https://browsercheck.qualys.com/?scan_type=js
 - Apply the more strict as possible site filtering, if a site is not categorized then block it by default and require to user to ask you the unlocking in order to obtains explanation about is utility:
 - For example as developer, access to <https://stackoverflow.com/> is mandatory but not <http://pastebin.com/>

Which possible mitigation?

- Limit the number of file type allowed to be downloaded directly using the Web Proxy (no EXE/WSH/VBS/JAR...)
 - Even Jar file, use a dedicated Proxy like Nexus or Artifactory !
- Disable WebRTC and install Ghostery:
 - <https://www.ghostery.com/try-us/download-browser-extension/>
 - <https://addons.mozilla.org/en-US/firefox/addon/happy-bonobo-disable-webrtc/>

Thanks you !!!

Question ?



If you want to see a live demo, come to me after the talk...
<http://excellium-services.com> - <http://www.emergenc6.com>